PANDAX / INDEPENDENT QA REFERENCE

Expected results for the release test set

Research snapshot: 7 September 2026 | Reference version 1.0

Use this answer key to assess component detection, named CVE matches, triage and release-to-release fixes. All vulnerability conclusions come from public online advisories and release evidence. PandaX scan output, scores and test verdicts were not used as evidence.

The repository was consulted only to identify the available input names and versions. This covers eight public release choices, the SmartHub directory/ZIP sample, and three additional Struts evaluation inputs. Arbitrary future uploads need their own baseline.

Available release	Principal expected result	Detail
OpenWrt 19.07.0	libubox CVE-2020-7248: affected	pp. 2-3
OpenWrt 19.07.1	Same CVE: fixed; DNSpooq checks still apply	pp. 2-3
OpenWrt 19.07.5	dnsmasq CVE-2020-25684 / 25686: affected	pp. 2-3
OpenWrt 19.07.6	Those dnsmasq CVEs: fixed by package backport	pp. 2-3
curl / libcurl 8.3.0	CVE-2023-38545: affected; runtime conditional	p. 4
curl / libcurl 8.4.0	CVE-2023-38545: fixed; other CVEs remain	p. 4
OpenSSL 1.0.1f	Heartbleed: affected if heartbeats compiled in	p. 5
OpenSSL 1.0.1g	Heartbleed: fixed; other CVEs remain	p. 5
SmartHub SH-100 2.3.1	Conditional component checks; synthetic sample	p. 6
Struts 2.5.12 full / min; 2.5.33 min	Supplemental archive and variant checks	p. 7

Coverage boundary: these are selected, independently verifiable checks, not an exhaustive list of every CVE in each archive. A fixed demo CVE does not mean a release is vulnerability-free. No expected total finding count is asserted. Sources are linked in each section and listed on pages 9-10.

OpenWrt: identify the packages

Target: official x86/64 generic root filesystem archives, without later package upgrades or a custom image build.

These versions were transcribed from the public OpenWrt image manifests, independently of PandaX. Preserve the full package revision. The ABI label **libubox20191228** is a package name, not the complete installed version. [M1] [M2] [M3] [M4]

19.07.0 / 19.07.1

Package	19.07.0	19.07.1
libubox20191228	2019-12-28-cd75136b-1	2020-01-20-43a103ff-1
libblobmsg-json	2019-12-28-cd75136b-1	2020-01-20-43a103ff-1
dnsmasq	2.80-15	2.80-15
ubus	2019-12-27-041c9d1c-1	2019-12-27-041c9d1c-1
rpcd	2019-11-10-77ad0de0-1	2019-11-10-77ad0de0-1
uhttpd	2019-12-22-5f9ae573-1	2019-12-22-5f9ae573-1

19.07.5 / 19.07.6

Package	19.07.5	19.07.6
libubox20191228	2020-05-25-66195aee-1	2020-05-25-66195aee-1
libblobmsg-json	2020-05-25-66195aee-1	2020-05-25-66195aee-1
dnsmasq	2.80-16.1	2.80-16.2
ubus	2019-12-27-041c9d1c-1	2019-12-27-041c9d1c-1
rpcd	2020-05-26-67c8a3fd-1	2020-05-26-67c8a3fd-1
uhttpd	2020-10-01-3abcc891-1	2020-10-01-3abcc891-1

Expected relationship evidence

OpenWrt identifies **ubus, rpcd and uhttpd** among users of the affected JSON conversion function. Associate the library finding with relevant consumers, while keeping runtime reachability separate. Merely finding both packages does not prove a particular executed call path. [W1]

Inventory acceptance: the selected packages should remain detectable in both sides of a comparison. A missing library on the fixed side is an inventory gap, not evidence that the vulnerability was repaired.

OpenWrt: CVE matrix

A = affected version/component; F = specifically fixed; X = excluded by package variant. Runtime exploitability still requires separate evidence.

Named CVE	19.07.0	19.07.1	19.07.5	19.07.6
CVE-2020-7248 [W1]	A	F	F	F
CVE-2020-25681 [W2]	X	X	X	X
CVE-2020-25682 [W2]	X	X	X	X
CVE-2020-25683 [W2]	X	X	X	X
CVE-2020-25684 [W2]	A	A	A	F
CVE-2020-25685 [W2]	X	X	X	X
CVE-2020-25686 [W2]	A	A	A	F
CVE-2020-25687 [W2]	X	X	X	X

Why five entries are excluded

The official manifests contain **dnsmasq**, not dnsmasq-full. OpenWrt explicitly limits CVE-2020-25681, 25682, 25683, 25685 and 25687 to its dnsmasq-full variant. Use that vendor-specific applicability statement, including its treatment of 25685. A generic upstream version match alone is insufficient. [W2] [M1] [M2] [M3] [M4]

If testing a custom dnsmasq-full installation, reopen all seven checks: affected through 19.07.5, fixed in 19.07.6. Record build features and DNSSEC configuration; do not carry the standard-image exclusion over to a different package. [W2]

Evidence of the fix

Comparison	Expected evidence
19.07.0 to 19.07.1	CVE-2020-7248 changes A to F; retain library inventory and tie the changed revision to the vendor fix. [W1] [M1] [M2]
19.07.5 to 19.07.6	CVE-2020-25684 and 25686 change A to F. dnsmasq remains upstream 2.80; revision changes from 16.1 to 16.2. [W2] [M3] [M4]

Triage: libubox needs an input path into blob-to-JSON serialization. DNS response validation issues need relevant DNS service behavior. A configuration mitigation can reduce exposure without changing an affected package into a patched one. [W1] [W2]

curl / libcurl: 8.3.0 and 8.4.0

Inputs are source distributions. Recognizing library source is not proof that a deployed application has loaded that library.

Expect libcurl source version **8.3.0** or **8.4.0**, respectively. The upstream version header identifies libcurl; the curl tool uses that library. Check an actual runtime library separately when testing an installed executable. [C5] [C1]

CVE / purpose	8.3.0	8.4.0	Specific fix
CVE-2023-38545: SOCKS5 overflow [C1]	A	F	8.4.0
CVE-2023-38546: cookie injection [C2]	A	F	8.4.0
CVE-2023-46218: cookie PSL bypass [C3]	A	A	8.5.0
CVE-2023-38039: header memory exhaustion [C4]	F	F	8.3.0

SOCKS5 triage for 8.3.0

For the heap overflow, look for SOCKS5 remote hostname resolution (such as socks5h), a sufficiently slow handshake, an accepted hostname longer than the download buffer, and buffer size below 65,541 bytes. Unknown proxy/build settings require **unresolved reachability**, not a clean verdict. [C1]

The curl CLI normally uses a 100 KiB buffer, preventing this heap overflow; a low --limit-rate can reduce it. The advisory also describes a separate hostname-length integer-overflow consequence despite a larger buffer. Do not conclude that the entire CVE is inapplicable solely from default buffer size. [C1]

Additional independent controls

Check	Expected triage
CVE-2023-38546	Affects libcurl handle duplication with cookie state and a readable file named none under the described conditions. It is not accessible through the curl CLI. [C2]
CVE-2023-46218	8.4.0 remains affected. Inspect cookie use and PSL support. Disabling cookies can remove this path without patching the version. [C3]
CVE-2023-38039	Both tested versions contain the named fix. An active finding needs evidence of a different or unpatched build. [C4]

Expected comparison: the two October 2023 CVEs change A to F; the later PSL finding stays A. This checks whether a report incorrectly treats 8.4.0 as globally clean.

OpenSSL: 1.0.1f and 1.0.1g

Test context: the bundled s_server application and its OpenSSL TLS library. Source-version evidence and runtime build evidence are different checks.

Named CVE	1.0.1f	1.0.1g	Specific fix
CVE-2014-0160: Heartbleed [O1]	A	F	1.0.1g
CVE-2014-0224: CCS MITM [O2]	A	A	1.0.1h
CVE-2014-0195: DTLS fragments [O2]	A	A	1.0.1h

Heartbleed expectations

The 1.0.1f source release is in the affected range; 1.0.1g contains the Heartbleed fix. OpenSSL documents a build mitigation using OPENSSL_NO_HEARTBEATS. For a running s_server, verify the library actually used and whether heartbeat support is compiled in. A source archive alone cannot establish its runtime configuration. [O1]

Findings that should survive the comparison

CVE-2014-0224 needs both a vulnerable client and server plus an attacker in the communication path. Both selected 1.0.1 releases precede its fix. CVE-2014-0195 applies to DTLS clients or servers; a TLS-only server does not exercise that DTLS path. Unknown protocol settings remain unresolved. [O2]

What evidence should be recorded

Layer	Expected observation
Inventory	Identify OpenSSL / libssl and the exact f or g release. For an executable, record linked or embedded library evidence rather than inferring solely from its filename.
CVE matching	Heartbleed is an affected-to-fixed control. The two June 2014 findings provide independent affected-in-both controls.
Triage	Keep build options, protocol mode and actual loaded library distinct from the release-level match.
Fix evidence	Cite the upstream Heartbleed advisory and preserve the identity/version evidence for both inputs. A missing finding alone does not establish a fix.

Expected comparison: 1.0.1g fixes Heartbleed; it should not receive an unconditional "no known vulnerabilities" conclusion. These historical fix boundaries are test references, not recommendations to deploy these releases.

05 / ORIGINAL DEMONSTRATION INPUT

SmartHub SH-100: 2.3.1

Applies to the directory and ZIP forms when they contain the same declared components. This is a synthetic sample, not an independently documented vendor firmware release.

The input declarations identify the component versions to check. Public sources below independently establish the named vulnerability and fix boundary. Each A is conditional on confirming that component/version in the submitted input; dependency declarations do not prove runtime deployment.

Component / version	Expected named finding	Fix for this CVE
jQuery 3.4.0	A: CVE-2020-11023 [J1]	3.5.0
lodash 4.17.15	A: CVE-2020-8203 [J2]	4.17.19
minimist 1.2.0	A: CVE-2021-44906 [J3]	1.2.6 (1.x)
node-forge 0.9.0	A: CVE-2022-24771 [J4]	1.3.0
Pillow 8.1.0	A: CVE-2021-25293 [P1]	8.1.1
Requests 2.19.1	A: CVE-2018-18074 [P2]	2.20.0
urllib3 1.24.1	A: CVE-2019-11324 [P3]	1.24.2
PyYAML 5.1	A: CVE-2020-14343 [P4]	5.4
Jinja2 2.10	A: CVE-2019-10906 [P5]	2.10.1
log4j-core 2.14.1	A: CVE-2021-44228 [L1]	2.15.0 initial fix

Triage questions that change runtime applicability

Does untrusted HTML reach jQuery DOM methods? Do attacker-controlled keys reach lodash or minimist? Does Forge verify affected RSA signatures? Does Pillow decode SGI input? Does Requests follow a same-host HTTPS-to-HTTP redirect with authorization? Is urllib3 given a restricted custom trust store? Is untrusted YAML loaded through affected loaders, or an untrusted template rendered in Jinja's sandbox? [J1] [J2] [J3] [J4] [P1] [P2] [P3] [P4] [P5]

Log4Shell needs log4j-core, not merely log4j-api. Confirm the JAR exists in the actual input and inspect the logging/JNDI path. 2.15.0 is only the initial fix boundary; later Log4j advisories document additional issues. [L1]

Do not infer libwebp from a requirements line. For CVE-2023-4863, inspect the actual wheel/native library. Pillow 10.0.1 shipped updated wheels with libwebp 1.3.2. A Pillow 8.1.0 declaration alone leaves that native-library check unresolved. [P6]

Apache Struts release archives

These are additional evaluation-harness targets, separate from the eight public release choices in the main selector.

Use the exact official full/minimum library archive, because optional plugins change the result. A library ZIP supplies component evidence; it does not supply an application's routes or deployment configuration. [A1] [A2] [A3]

Target	CVE-2018-11776 S2-057	CVE-2023-50164 S2-066	CVE-2017-9805 S2-052
2.5.12 full libraries	A	A	A: REST plugin present
2.5.12 minimum libraries	A	A	X: REST plugin absent
2.5.33 minimum libraries	F	F	X: plugin absent; version also fixed

Version boundaries: S2-057 fixes the 2.5 branch in 2.5.17; S2-066 in 2.5.33; S2-052 in 2.5.13. These checks do not imply 2.5.33 is free of later vulnerabilities. [S1] [S2] [S3]

Inventory and triage requirements

Check	Expected reasoning
Core identity	Locate struts2-core with version 2.5.12 or 2.5.33 as selected. Missing core identification is an inventory failure or unresolved scan.
REST plugin identity	Establish whether struts2-rest-plugin exists in the exact archive. If absent, do not assign S2-052 to the archive merely because core is 2.5.12. [S1]
S2-052 reachability	Requires REST plugin XML processing through the affected XStream handler. Plugin presence alone does not prove that XML endpoints are enabled. [S1]
S2-057 reachability	Check alwaysSelectFullNamespace and the missing/wildcard namespace and result/URL-tag conditions in the advisory. [S2]
S2-066 reachability	Check use of the affected file upload logic. An archive of libraries cannot establish whether a deployed application exposes it. [S3]

Independent archive check: the freshly downloaded full ZIP contains 93 JARs, including struts2-core 2.5.12, struts2-rest-plugin 2.5.12 and XStream 1.4.8. Each minimum ZIP contains 8 JARs, including its selected core version and no REST plugin. These are ZIP-entry counts, not scanner output. [A1] [A2] [A3]

07 / TESTING WORKSHEET

Record what agrees - and fails

This is a proposed manual QA procedure, not a claim about PandaX's observed behavior. No scan was run to derive this reference.

Verdict	Use it when
PASS	The observed component/version, named CVE disposition and supporting evidence agree with this reference.
FAIL: missed finding	An A component/version is established, but the named CVE is missing or incorrectly marked fixed.
FAIL: false positive	A named F or X case is reported as currently affected without evidence overturning the fix or exclusion.
UNRESOLVED	Input identity, package variant, build/configuration or retrieval evidence is missing. Preserve any tool error; do not count this as PASS.

Keep release-level affected status separate from runtime reachability. For extra CVEs outside this selected reference, open the cited vendor advisory before calling them false positives. Deduplicate aliases by CVE; do not score raw identifier counts as independent findings.

Run / input	Inventory	CVE checks	Triage / notes
OpenWrt 19.07.0			
OpenWrt 19.07.1			
OpenWrt 19.07.5			
OpenWrt 19.07.6			
curl 8.3.0			
curl 8.4.0			
OpenSSL 1.0.1f			
OpenSSL 1.0.1g			
SmartHub directory			
SmartHub ZIP			
Struts 2.5.12 full			
Struts 2.5.12 min			
Struts 2.5.33 min			

For each mismatch, save: input URL/hash, scan date, scanner/feed versions, component identity, expected vs observed CVE status, source ID, configuration evidence and error text. Preserve both sides of every release comparison.

This reference does not prescribe exact SBOM totals, live EPSS scores, KEV counts, regulatory deadlines or compliance scores. Those require separate, dated evidence beyond these release advisories.

Source register 1 of 2

All sources consulted for this reference on 7 September 2026. Click a title or URL to open the original evidence.

[W1] OpenWrt: libubox advisory, 31 Jan 2020
https://openwrt.org/advisory/2020-01-31-2

[W2] OpenWrt: DNSpooq advisory, 19 Jan 2021
https://openwrt.org/advisory/2021-01-19-1

[M1] OpenWrt 19.07.0: official x86/64 generic manifest
https://downloads.openwrt.org/releases/19.07.0/targets/x86/64/openwrt-19.07.0-x86-64-generic.manifest

[M2] OpenWrt 19.07.1: official x86/64 generic manifest
https://downloads.openwrt.org/releases/19.07.1/targets/x86/64/openwrt-19.07.1-x86-64-generic.manifest

[M3] OpenWrt 19.07.5: official x86/64 generic manifest
https://downloads.openwrt.org/releases/19.07.5/targets/x86/64/openwrt-19.07.5-x86-64-generic.manifest

[M4] OpenWrt 19.07.6: official x86/64 generic manifest
https://downloads.openwrt.org/releases/19.07.6/targets/x86/64/openwrt-19.07.6-x86-64-generic.manifest

[C1] curl: SOCKS5 heap buffer overflow
https://curl.se/docs/CVE-2023-38545.html

[C2] curl: cookie injection with none file
https://curl.se/docs/CVE-2023-38546.html

[C3] curl: cookie mixed case PSL bypass
https://curl.se/docs/CVE-2023-46218.html

[C4] curl: HTTP headers eat all memory
https://curl.se/docs/CVE-2023-38039.html

[C5] curl: versions and source version identification
https://curl.se/docs/versions.html

[O1] OpenSSL: Heartbleed advisory, 7 Apr 2014
https://openssl-library.org/news/secadv/20140407.txt

[O2] OpenSSL: security advisory, 5 Jun 2014
https://openssl-library.org/news/secadv/20140605.txt

[J1] jQuery maintainer: CVE-2020-11023
https://github.com/jquery/jquery/security/advisories/GHSA-jpcq-cgw6-v4j6

[J2] GitHub reviewed advisory: lodash CVE-2020-8203
https://github.com/advisories/GHSA-p6mc-m468-83gw

Source register 2 of 2

All sources consulted for this reference on 7 September 2026. Click a title or URL to open the original evidence.

[J3] GitHub reviewed advisory: minimist CVE-2021-44906
https://github.com/advisories/GHSA-xvch-5gv4-984h

[J4] Forge maintainer: CVE-2022-24771
https://github.com/digitalbazaar/forge/security/advisories/GHSA-cfm4-qjh2-4765

[P1] Pillow 8.1.1 security release notes
https://pillow.readthedocs.io/en/stable/releasenotes/8.1.1.html

[P2] Requests maintainer: 2.20.0 release history
https://github.com/psf/requests/blob/main/HISTORY.md

[P3] urllib3 team disclosure: CVE-2019-11324
https://seclists.org/oss-sec/2019/q2/50

[P4] GitHub reviewed advisory: PyYAML CVE-2020-14343
https://github.com/advisories/GHSA-8q59-q68h-6hv4

[P5] Jinja maintainer: 2.10.1 security release
https://palletsprojects.com/blog/jinja-2-10-1-released

[P6] Pillow 10.0.1: updated libwebp wheels
https://pillow.readthedocs.io/en/stable/releasenotes/10.0.1.html

[L1] Apache Logging: Log4j security advisories
https://logging.apache.org/security.html

[S1] Apache Struts: S2-052 / CVE-2017-9805
https://cwiki.apache.org/confluence/display/WW/S2-052

[S2] Apache Struts: S2-057 / CVE-2018-11776
https://cwiki.apache.org/confluence/display/WW/S2-057

[S3] Apache Struts: S2-066 / CVE-2023-50164
https://cwiki.apache.org/confluence/display/WW/S2-066

[A1] Apache archive: Struts 2.5.12 full libraries
https://archive.apache.org/dist/struts/2.5.12/struts-2.5.12-lib.zip

[A2] Apache archive: Struts 2.5.12 minimum libraries
https://archive.apache.org/dist/struts/2.5.12/struts-2.5.12-min-lib.zip

[A3] Apache archive: Struts 2.5.33 minimum libraries
https://archive.apache.org/dist/struts/2.5.33/struts-2.5.33-min-lib.zip

Evidence method

Vendor advisories establish affected/fixed ranges and conditions. Official image manifests establish the OpenWrt package revisions. Maintainer notices and reviewed package advisory records establish the synthetic sample's conditional checks. Release-to-CVE matrix cells are deductions from those sources, not copied scanner verdicts.